

The Hacking Methodology: Compromising a target

Abik Maharjan
Lalitpur, Nepal
maharjanebik061@gmail.com

Abstract—This research paper analyzes the multiple procedures employed to compromise any computer network. Understanding these steps is essential for defending against threat actors. This paper uncovers each phase that includes recon, scanning and enumeration, exploitation, privilege escalation, post exploitation.

Keywords—hacking, methodology, compromise

I. INTRODUCTION

Hacking is the process of making a computer program behave in a way that was not intended by the developer. It is not always technical. Hackers may manipulate the psychology of a person such that they divulge confidential information.

The hacking process consists of a series of procedures:

- A. Reconnaissance
- B. Scanning and Enumeration
- C. Exploitation
- D. Privilege Escalation
- E. Post-Exploitation

II. RECONNAISSANCE

The first step is to gather as much information about the target as possible. The information includes the company name, its subsidiary, list of employees, their email address, phone numbers. They can be obtained from social media, job vacancy announcement, newsletters. Some of these can be automated using tools like amass and assetfinder. These tools automatically find assets related to the target company. This is done without getting in contact with the target.

Tools	Sources
amass	360PassiveDNS, Ahrefs, AnubisDB, BeVigil, BinaryEdge, BufferOver, BuiltWith, C99, Chaos, CIRCL, DNSDB, DNSRepo, Deepinfo, Detectify, FOFA, FullHunt, GitHub, GitLab, GrepApp, Greynoise, HackerTarget, Hunter, IntelX, LeakIX, Maltiverse, Mnemonic, Netlas, Pastebin, PassiveTotal, PentestTools, Pulsedive, Quake, SOCRadar, Searchcode, Shodan, Spamhaus, Sublist3rAPI, SubdomainCenter, ThreatBook, ThreatMiner, URLScan, VirusTotal, Yandex, ZETAlytics, ZoomEye [1]
assetfinder	crt.sh, certspotter, hackertarget, threatcrowd, wayback machine, dns.bufferover.run, facebook, virustotal, findsubdomains [2]

TABLE 1 RECONNAISSANCE TOOLS

III. SCANNING AND ENUMERATION

This step involves actively engaging with the systems in the target network. Each system in the network is scanned to discover the applications and services that are running. Ports ranging from 1 to 65535 are probed to see if they are providing a service. A tool like nmap is used to find the services and applications running on those open

ports. Furthermore, their versions, device operating system, hops before reaching the machine are also determined.

Tools	Purpose
nmap	Port scanning, network discovery, security auditing, version detection
rustscan	Port scanning
gobuster	Bruteforce: • URIs • Subdomains • Virtual Hostnames • TFTP servers • Open Amazon S3 buckets • Open Google Cloud buckets
Nessus	Vulnerability scanner
Social Engineering	Finding confidential information from a person

TABLE 2 SCANNING AND ENUMERATION TOOLS

IV. EXPLOITATION

The vulnerabilities and weaknesses present on a system or application are leveraged to gain unauthorized access to the machine. Older versions of the services that are currently in use might have a publicly available exploit. If a vulnerability exists but there are no public exploits, you can make a custom exploit to manipulate the machine. Examples include bruteforcing login credentials, authentication bypass, stack overflow, SQL injection, command injection, Cross-Site Scripting and others.

V. PRIVILEGE ESCALATION

Multiple users exist on a system. Each user can have different access level. The root(in Linux) and administrator(in Windows) have the highest access levels. Successful exploitation usually gives the attacker a user account with low access level meaning they have limited set of operations that can be performed.

Privilege escalation is the method of gaining unauthorized access to another user's account. Some techniques used to privilege escalation include sudo shell escape sequence, misconfigured cronjobs, leveraging suid binaries, kernel level exploits, readable /etc/shadow, dll hijacking.

A. MISCONFIGURED CRONJOBS

Cronjobs are scheduled tasks. They are used to run a script or command at certain intervals. The cronjob may run a script that is writable by the current user allowing the attacker to gain a reverseshell of another user.

B. SUID binaries

A file with SUID always executes as the user who owns the file, regardless of the user passing the command. [3]

Misconfigured SUID binaries can lead to privilege escalation.

C. READABLE SHADOW FILE

In linux systems, /etc/shadow file stores the hashed password for all users. Although the hashes are irreversible, they can be cracked if the passwords are weak.

Tool	Feature
johntheripper	Password recovery
hashcat	Password recovery

TABLE 3 PASSWORD RECOVERY TOOLS

D. DLL HIJACKING

DLL hijacking is a method of injecting malicious code into an application by exploiting the way some Windows applications search and load Dynamic Link Libraries (DLL). [4]

A windows program will search for DLLs in pre-defined search paths. A malicious DLL is created and its path is placed in the program's search parameter. When the program is executed next time, the malicious DLL also gets executed.

VI. POST-EXPLOITATION

A. *PIVOTING*

Every machine in the network is not exposed to the public, however, they may be accessible by a machine that is exposed to the public. After compromising the publicly exposed machine, other systems in the same network are scanned and enumerated to find potential vulnerabilities.

B. *PERSISTENCE*

The vulnerability that gave the attacker access to the machine might get patched. Persistence allows the threat actor to access the previously compromised machine even if the vulnerability is patched.

REFERENCES

- [1] Owasp-Amass, "GitHub - owasp-amass/amass: In-depth attack surface mapping and asset discovery," GitHub. <https://github.com/owasp-amass/amass>
 - [2] Tomnomnom, "GitHub - tomnomnom/assetfinder: Find domains and subdomains related to a given domain," GitHub. <https://github.com/tomnomnom/assetfinder>
 - [3] Tcarriga, "Linux permissions: SUID, SGID, and sticky bit," Enable Sysadmin, Mar. 2023, [Online]. Available: <https://www.redhat.com/sysadmin/suid-sgid-sticky-bit>
 - [4] "What is DLL Hijacking? The Dangerous Windows Exploit | UpGuard." <https://www.upguard.com/blog/dll-hijacking>
- J. Erickson, Hacking: The Art of Exploitation, 2nd Edition. 2021. [Online]. Available: <https://dl.acm.org/citation.cfm?id=1407147>
- TryHackMe, "TryHackMe | Cyber Security Training," TryHackMe. <https://tryhackme.com/>